

序号	检查项目	管理要求	备
1	权限管理	应建立分级授权制度，定期复核用户权限分配，确保最小权限原则落地实施。	定期
2	日志审计	应保存关键操作日志不少于六个月，日志应包含操作时间、操作人、操作对象、	不
3	数据备份	应建立定时备份机制，生产数据每日全量备份，备份文件异地存储，定期验证可	以
4	访问控制	应实施基于角色的访问控制（RBAC），敏感操作需二次确认，远程访问需通过VBA	访问
5	账号管理	应建立全生命周期账号管理流程，员工离职当日注销账号，共享账号禁用，密	码
6	变更管理	所有生产环境变更须提交变更申请，经审批后方可实施，变更过程全程录像，变	更
7	风险评估	应每季度开展一次信息安全风险评估，识别资产、威胁、脆弱性，评估风险等级	每
8	供应商管理	应对外部服务商进行安全背景审查，签订数据保护协议，明确数据处理责任，定	期
9	安全培训	应每年度组织员工信息安全培训，覆盖密码安全、社会工程学、数据分类分级	每
10	数据归档	超过保存期限的业务数据应按规定归档，归档数据应保持可查询性，归档过程	全
11	异常处置	应建立信息安全事件响应预案，明确事件分级、处置流程、升级路径，每半年	至
12	应急响应	应建立业务连续性应急预案，明确RTO/RPO指标，定期开展灾难恢复演练，确	定